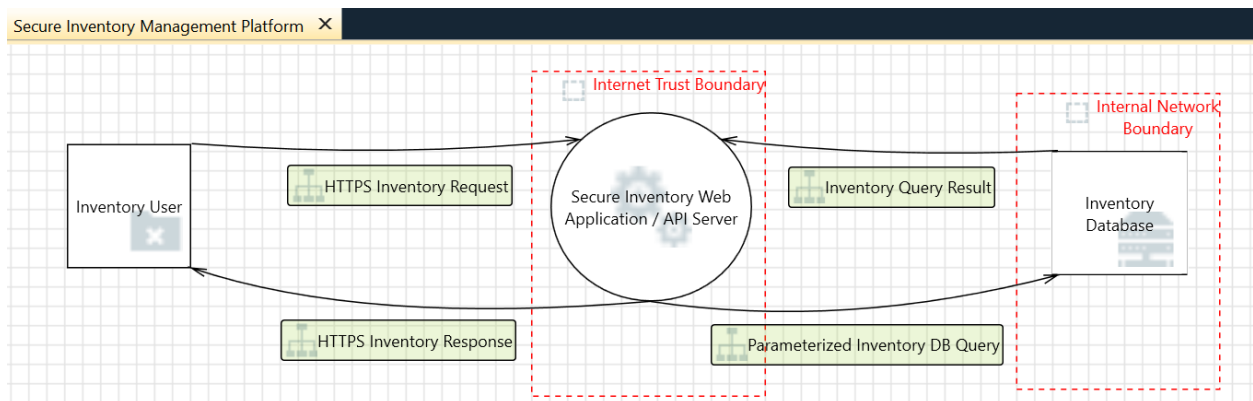


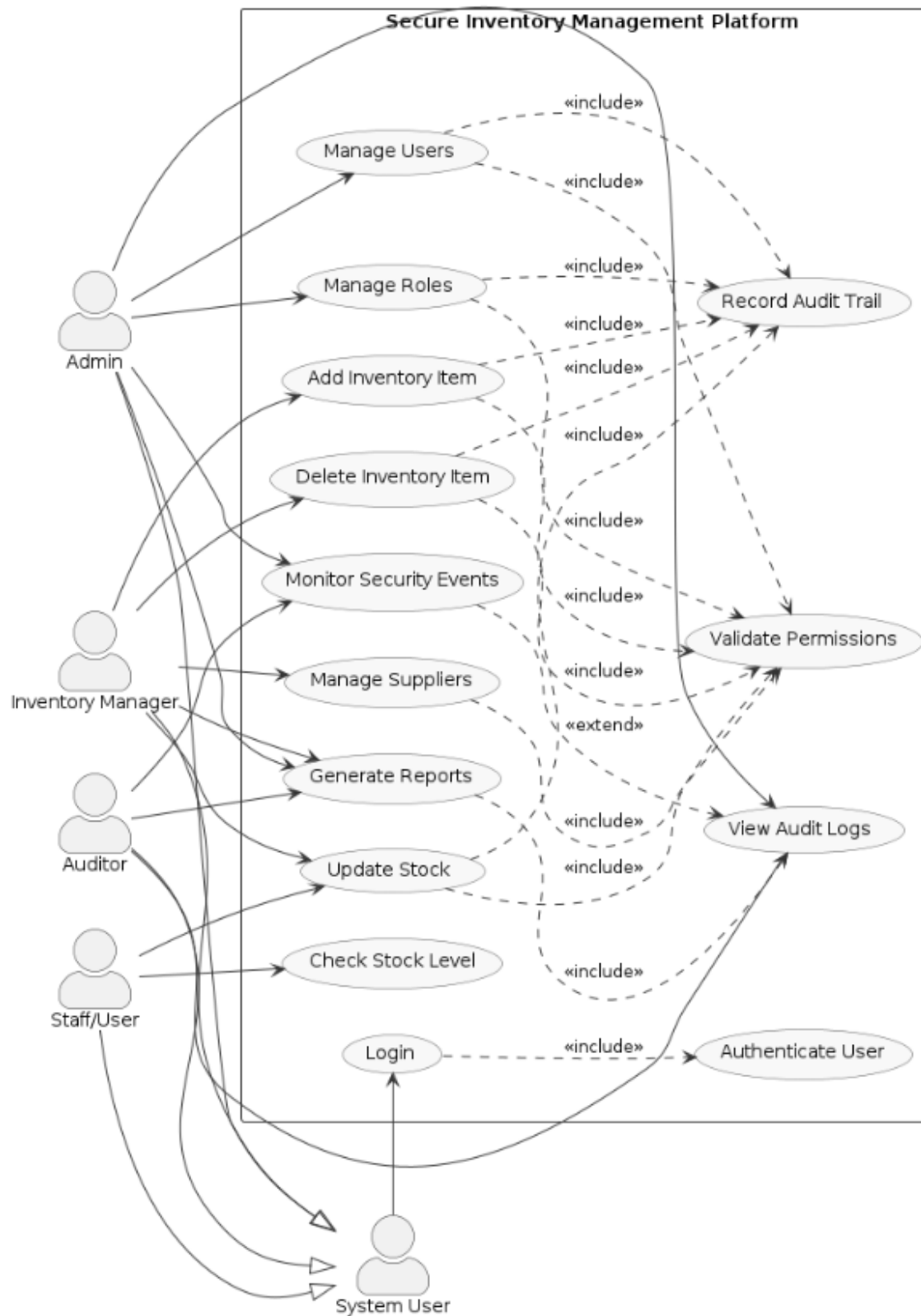
Phase 1

Threat Modeling Diagram



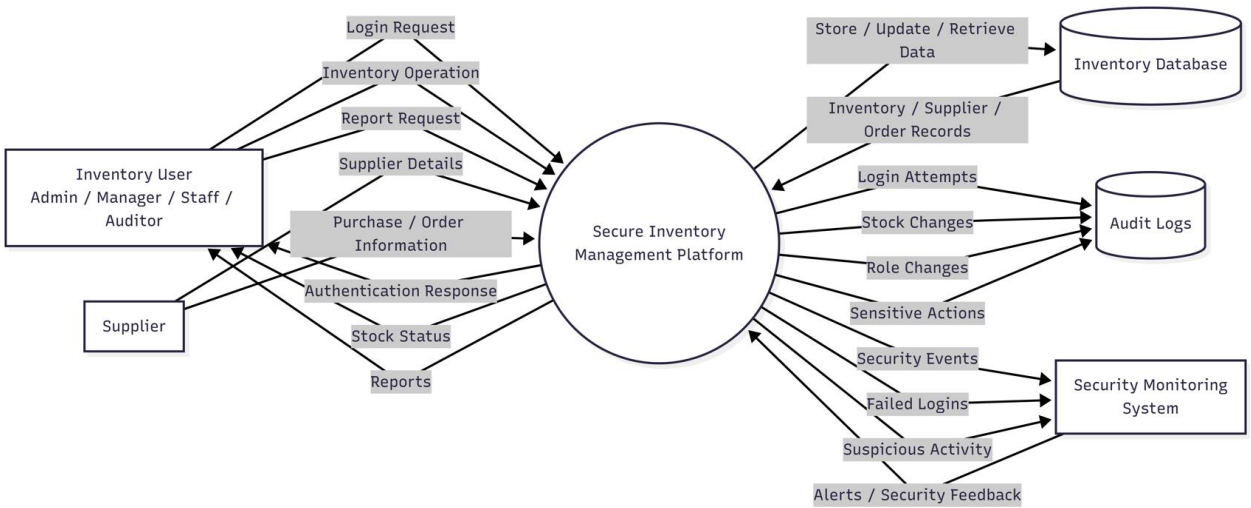
Use Case Diagram

Secure Inventory Management Platform - Use Case Diagram



The Use Case Diagram shows how different roles interact with the Secure Inventory Management Platform. The main actors are Admin, Inventory Manager, Staff/User, Auditor, and System User. Admin can manage users, roles, audit logs, and security events. Inventory Manager can manage inventory items, suppliers, stock updates, and reports. Staff/User has limited access such as login and checking stock levels. Auditor can view reports, audit logs, and security-related activities. The diagram also shows authentication, permission validation, and audit trail recording for secure access control.

Data Flow Diagram



The Data Flow Diagram (DFD) illustrates how data moves between users, suppliers, the Secure Inventory Management Platform, databases, and security monitoring systems. Inventory users send login requests, inventory operations, supplier information, and report requests to the platform. The platform processes these requests and stores inventory, supplier, order, and user-related data in the Inventory Database. Important actions such as login attempts, stock changes, and role modifications are recorded in the Audit Logs. Security-related events, failed logins, and suspicious activities are forwarded to the Security Monitoring System. The monitoring system analyzes these events and generates alerts or security feedback when necessary. This data flow ensures secure processing, storage, auditing, and monitoring of inventory operations.

STRIDE Summary Table based on Threat Modelling

STRIDE Category	Identified Threats in Secure Inventory Management Platform	Possible Impact	Recommended Mitigation

Spoofing	Spoofing the Inventory User External Entity	Attacker may act as Admin, Inventory Manager, Staff, or Auditor and access inventory records.	Strong authentication, MFA for privileged roles, secure password hashing, account lockout, and server-side session validation.
Spoofing	Spoofing the Secure Inventory Web Application Process	Users may be tricked into entering credentials on a fake platform.	Valid TLS certificates, HSTS, secure domain configuration, anti-phishing awareness, and MFA.
Spoofing	Spoofing of Destination Data Store Inventory Database	Application may send data to an attacker-controlled database.	Secure connection strings, database TLS, certificate validation, network policies, and secret management.
Tampering	Potential Lack of Input Validation for Secure Inventory Web Application	Product fields, supplier fields, stock quantities, and report filters may be manipulated.	Allow-list validation, schema validation, server-side checks, prepared statements, and output encoding.
Tampering	The Inventory Database Could Be Corrupted	Stock, supplier, or order records may be modified or corrupted.	Parameterized queries, ORM validation, database constraints, transactions, and integrity checks.
Repudiation	Inventory Database Denies Potentially Writing Data	It may be difficult to prove whether stock or supplier changes were stored correctly.	Database transaction logs, application audit logs, immutable event records, and backup verification.
Repudiation	Potential Data Repudiation by Secure Inventory Web Application	Users may deny submitting stock changes, supplier edits, item deletions, or role updates.	Tamper-resistant audit logs with user ID, IP address, timestamp, action, entity ID, and before/after values.

Information Disclosure	Data Flow Sniffing on HTTPS Inventory Request	Credentials, JWT/session cookies, supplier data, and stock updates may be exposed.	HTTPS/TLS 1.3, HSTS, secure cookies, certificate validation, and disabled insecure protocols.
Denial of Service	Potential Excessive Resource Consumption for Secure Inventory Web Application or Inventory Database	Large reports or unbounded queries may degrade system performance.	Pagination, query limits, indexes, timeouts, caching, and database connection pooling.
Denial of Service	Data Flow HTTPS Inventory Request Is Potentially Interrupted	Legitimate inventory operations may be delayed or blocked.	Rate limiting, request throttling, WAF rules, reverse proxy limits, and monitoring alerts.
Denial of Service	Potential Process Crash or Stop for Secure Inventory Web Application	Malformed requests, large uploads, or repeated report generation may crash the application.	Payload size validation, resource limits, queued reports, timeouts, and graceful error handling.
Elevation of Privilege	Elevation Using Impersonation	Staff or lower-privileged users may perform Admin or Manager-level functions.	Backend RBAC, least privilege, role-claim validation, and access decision logging.
Elevation of Privilege	Secure Inventory Web Application May be Subject to Remote Code Execution	Unsafe file imports may allow attacker-controlled code execution.	Validate file type and size, disable direct execution, scan uploads, sandbox parsing, and avoid shell commands.
Elevation of Privilege	Cross Site Request Forgery	Authenticated users may be forced to submit unauthorized stock or supplier changes.	Anti-CSRF tokens, SameSite cookies, origin checks, and re-authentication for critical changes.

Elevation of Privilege	Elevation by Changing the Execution Flow in Secure Inventory Web Application	Attackers may manipulate routes or parameters to access restricted functionality.	Strict server-side authorization, deny-by-default routing, secure middleware checks, and access control tests.
-------------------------------	--	---	--

PASTA Threat Modelling

Stage 1: Define Business Objectives

The main objective of the **Secure Inventory Management Platform** is to securely manage users, roles, inventory items, stock quantities, suppliers, purchase/order records, reports, and audit logs. The platform must protect inventory accuracy, prevent unauthorized stock modification, secure supplier and order data, and maintain accountability through audit logging. The system must ensure confidentiality, integrity, and availability of business-critical inventory data.

Stage 2: Define Technical Scope

The system is a web-based application accessed through a browser by Admin, Inventory Manager, Staff/User, and Auditor roles. The main technical components include the frontend interface, backend API server, authentication/session mechanism, inventory database, audit log storage, and optional monitoring/SIEM services. Inventory operations are performed through HTTPS APIs, and the database is placed inside an internal network boundary.

Stage 3: Application Decomposition

The application can be decomposed into the following major modules:

Module	Purpose
Authentication Module	Handles login, logout, password verification, and session validation.
User and Role Management Module	Manages users, roles, permissions, and privileged access.
Inventory Management Module	Handles item creation, stock updates, item deletion, and stock status.
Supplier Management Module	Manages supplier records and purchase/order information.

Reporting Module	Generates stock reports, supplier reports, and inventory summaries.
Audit Logging Module	Records login attempts, stock changes, role changes, and sensitive actions.
Database Module	Stores users, roles, inventory records, suppliers, orders, and audit data.
Security Monitoring Module	Detects failed logins, suspicious activity, and abnormal request patterns.

Stage 4: Threat Analysis

The main threats identified for the platform are spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege. Spoofing threats may allow attackers to impersonate users, the application, or the database. Tampering threats may corrupt stock, supplier, and order records. Repudiation threats may prevent proof of user actions. Information disclosure may expose credentials, tokens, supplier data, and inventory records. Denial of service may affect availability, while elevation of privilege may allow unauthorized users to access restricted functions.

Stage 5: Vulnerability Analysis

The following weaknesses may enable the identified threats:

Weakness	Related Threat
Weak authentication	User spoofing and account takeover
Missing MFA	Admin or manager impersonation
Poor RBAC checks	Elevation of privilege
Lack of input validation	Tampering and database corruption
Unsafe file import	Remote code execution
Missing CSRF protection	Unauthorized state-changing requests
Weak TLS configuration	Information disclosure
Unbounded queries	Excessive resource consumption

Missing audit logs	Repudiation
Weak database identity validation	Database spoofing

Stage 6: Attack Modelling

Attack Scenario 1: Unauthorized Stock Modification

An attacker logs in as a normal Staff/User and observes stock update API requests. The attacker modifies request parameters to perform restricted inventory operations. If backend authorization is weak, the attacker may update stock quantities, delete items, or modify supplier records. This can cause incorrect inventory values, fake shortages, incorrect reports, and business loss.

Mitigation: Apply strict backend RBAC, validate role claims on every sensitive API, log all stock changes, and require approval for critical inventory updates.

Attack Scenario 2: Database Tampering

An attacker submits malicious or unexpected input through product fields, supplier fields, stock quantities, or report filters. If the application does not validate input properly, corrupted or harmful data may reach the database. This can affect inventory accuracy and supplier/order records.

Mitigation: Use allow-list validation, prepared statements, ORM validation, database constraints, transactions, and integrity checks.

Attack Scenario 3: Account Spoofing

An attacker uses stolen or guessed credentials to impersonate an Admin, Inventory Manager, Staff/User, or Auditor. If authentication is weak, the attacker may access sensitive inventory records and perform unauthorized actions.

Mitigation: Use strong password hashing, MFA for privileged roles, account lockout, secure session validation, and login monitoring.

Stage 7: Risk and Impact Analysis

The highest-risk threats are user spoofing, elevation using impersonation, input tampering, database corruption, remote code execution, CSRF, broken access control, and HTTPS data sniffing. These risks are serious because they can directly affect inventory accuracy, business operations, sensitive supplier data, and user accountability. Denial-of-service threats are also important because inventory systems must remain available for stock checking, reporting, and order processing.

Risk Matrix based on threat modelling

ID	Threat	STRIDE Category	Likelihood	Impact	Risk Level	Mitigation
R-01	Spoofing the Inventory User External Entity	Spoofing	High	High	Critical	Strong authentication, MFA, password hashing, account lockout, and session validation.
R-02	Elevation Using Impersonation	Elevation of Privilege	Medium	High	High	Backend RBAC, least privilege, role-claim validation, and access decision logging.
R-03	Potential Lack of Input Validation	Tampering	High	High	Critical	Allow-list validation, schema validation, prepared statements, and output encoding.
R-04	Spoofing the Web Application Process	Spoofing	Medium	High	High	TLS certificates, HSTS, secure domain configuration, anti-phishing awareness, and MFA.
R-05	Spoofing of Destination Inventory Database	Spoofing	Medium	High	High	Secure connection strings, database TLS, certificate validation, network policies,

						and secret management.
R-06	Excessive Resource Consumption	Denial of Service	High	Medium	High	Pagination, query limits, indexes, timeouts, caching, and connection pooling.
R-07	Database Denies Writing Data	Repudiation	Medium	High	High	Transaction logs, application audit logs, immutable event records, and backup verification.
R-08	Inventory Database Could Be Corrupted	Tampering	Medium	High	High	Parameterized queries, ORM validation, database constraints, transactions, and integrity checks.
R-09	Remote Code Execution	Elevation of Privilege	Medium	Critical	Critical	File validation, upload scanning, sandbox parsing, and avoiding shell execution.
R-10	HTTPS Inventory Request Interrupted	Denial of Service	Medium	Medium	Medium	Rate limiting, throttling, WAF rules, reverse proxy limits, and monitoring alerts.
R-11	Cross Site Request Forgery	Elevation of Privilege	Medium	High	High	Anti-CSRF tokens, SameSite cookies, origin checks, and re-authentication.

R-12	Changing Execution Flow	Elevation of Privilege	Medium	High	High	Server-side authorization, deny-by-default routing, middleware checks, and access control tests.
R-13	Process Crash or Stop	Denial of Service	Medium	Medium	Medium	Payload size validation, resource limits, queued reports, timeouts, and graceful error handling.
R-14	HTTPS Request Sniffing	Information Disclosure	Medium	High	High	HTTPS/TLS 1.3, HSTS, secure cookies, certificate validation, and disabled insecure protocols.
R-15	Data Repudiation by Web Application	Repudiation	Medium	High	High	Tamper-resistant audit logs with user ID, IP, timestamp, action, entity ID, and before/after values.

OWASP ASVS Mapping based on security requirements

OWASP ASVS Area	Mapped Security Requirements	Application in Secure Inventory Management Platform
Authentication Security	SR-01, SR-02, SR-03	The system requires valid login credentials, strong password rules, secure password reset,

		and MFA for Admin and Inventory Manager roles.
Session Management	SR-04	Sessions or JWT tokens must expire properly, use secure cookies, validate tokens on each request, and support logout.
Access Control	SR-05, SR-06, SR-07	RBAC, least privilege, and backend authorization checks ensure that Admin, Inventory Manager, Staff/User, and Auditor can only access permitted features.
Business Logic Security	SR-08, SR-09, SR-10	Inventory records, stock changes, supplier details, and purchase/order records must be protected from unauthorized changes and misuse.
Input Validation	SR-11	All user input must be validated using allow-list rules, type checks, length checks, and business rules before processing.
Injection Prevention	SR-12	Prepared statements, ORM validation, and safe query handling must be used to prevent SQL Injection and related injection attacks.
Cross-Site Scripting Prevention	SR-13	Product names, supplier names, notes, reports, and displayed fields must be sanitized and encoded to prevent XSS.
API and Request Security	SR-14	APIs must be protected using rate limiting, throttling, anti-CSRF controls, and request origin validation for state-changing actions.
Cryptography and Transport Security	SR-15, SR-16	HTTPS/TLS must be used for communication, passwords must be strongly hashed, and secrets must not be stored in plaintext.
Logging and Monitoring	SR-17, SR-18	Login attempts, failed logins, inventory changes, supplier/order changes, role changes, report downloads, and suspicious activity must be logged and monitored.

Data Protection and Recovery	SR-19	Inventory records, supplier/order data, and audit logs must support secure backup and recovery.
Security Verification	SR-20	The system must be reviewed and tested for authentication, access control, injection, XSS, API abuse, logging, and data protection issues.

NIST CSF Mapping based on sr

NIST CSF Function	Mapped Controls / Requirements	Application in Secure Inventory Management Platform
Identify	SR-05, SR-06, SR-08, SR-10	The system identifies important assets, user roles, permissions, inventory records, supplier data, order records, and access boundaries.
Protect	SR-01, SR-02, SR-03, SR-04, SR-05, SR-06, SR-07, SR-11, SR-12, SR-13, SR-14, SR-15, SR-16	Authentication, MFA, secure sessions, RBAC, least privilege, input validation, injection prevention, XSS prevention, CSRF protection, HTTPS/TLS, and secure storage protect the system from misuse.
Detect	SR-17, SR-18	Audit logging and monitoring help detect failed logins, suspicious activity, unusual stock changes, excessive API requests, and sensitive actions.
Respond	SR-17, SR-18, SR-20	Logs, alerts, and security verification support investigation and response when suspicious activity or security violations occur.
Recover	SR-19	Backup and recovery controls help restore inventory records, supplier/order data, and audit logs after failure, corruption, or attack.

MITRE ATT&CK Mapping based on sr and threat modelling

Threat Scenario	MITRE ATT&CK Area	Related Security Requirements	Explanation / Attack Relevance	Mitigation
Attacker uses stolen credentials to log in as Admin, Inventory Manager, Staff/User, or Auditor	Valid Accounts / Credential Access	SR-01, SR-02, SR-03, SR-04	Weak authentication may allow attackers to impersonate real users and access protected inventory functions.	Strong authentication, strong password policy, MFA, secure sessions, account lockout, and session validation.
Attacker performs brute-force login attempts	Brute Force / Credential Access	SR-01, SR-02, SR-03, SR-14, SR-18	Repeated login attempts may be used to guess passwords or compromise privileged accounts.	Strong passwords, MFA, rate limiting, monitoring, and failed login alerts.
Staff/User tries to access Admin or Inventory Manager functions	Privilege Escalation / Valid Accounts	SR-05, SR-06, SR-07	A lower-privileged user may attempt to perform restricted actions such as role changes, item deletion, or supplier modification.	RBAC, least privilege, backend authorization checks, deny-by-default access, and access control testing.
Attacker abuses public inventory APIs	Exploit Public-Facing Application / API Abuse	SR-07, SR-11, SR-12, SR-14, SR-20	Public-facing APIs may be abused through manipulated parameters, excessive requests, or unsafe input.	Server-side authorization, input validation, safe query handling, rate limiting, CSRF protection, and

				API security testing.
Attacker modifies stock quantity or supplier/order records	Data Manipulation	SR-08, SR-09, SR-10, SR-17	Unauthorized changes to inventory records can create fake stock levels, incorrect reports, and business loss.	Inventory permissions, stock change control, supplier/order protection, and audit logging.
Attacker injects malicious SQL payload into search, login, report, or supplier fields	Exploit Public-Facing Application / Injection	SR-11, SR-12, SR-20	Unsafe input handling may allow attackers to access, modify, or delete database records.	Allow-list validation, prepared statements, ORM validation, safe query handling, and security testing.
Attacker stores malicious script in product, supplier, or report fields	Client-Side Execution / XSS	SR-11, SR-13, SR-20	Stored or reflected XSS may affect users viewing inventory, supplier, or report pages.	Input validation, output encoding, sanitization, safe templates, and XSS testing.
Malicious website forces an authenticated user to submit stock or supplier changes	CSRF / Forced Request Abuse	SR-04, SR-14	If authenticated requests depend only on cookies, attackers may force unwanted state-changing requests.	SameSite cookies, anti-CSRF tokens, origin validation, secure sessions, and re-authentication for critical actions.
Attacker sniffs inventory	Network Sniffing /	SR-04, SR-15, SR-16	Credentials, JWT/session cookies, supplier	HTTPS/TLS, secure cookies, certificate

requests or responses	Information Disclosure		data, inventory updates, and reports may be exposed if transport security is weak.	validation, strong token handling, and secure storage.
Attacker overloads login, report, search, or inventory APIs	Denial of Service	SR-14, SR-18, SR-19	Excessive requests, large reports, or unbounded queries may slow down or crash the platform.	Rate limiting, throttling, monitoring, alerts, backup, recovery, and resource limits.
Malicious file import causes unsafe execution or application compromise	Execution / Exploitation	SR-11, SR-14, SR-16, SR-20	If inventory import files are not validated, malicious content may trigger unsafe behavior.	File validation, safe parsing, secret protection, no shell execution, and security verification.
User denies changing stock or downloading reports	Repudiation / Defense Evasion Support	SR-09, SR-17, SR-18	Without proper logs, users may deny stock changes, supplier edits, role changes, or report downloads.	Tamper-resistant audit logs, monitoring, timestamps, user ID, IP address, affected record, and action details.
Attacker tampers with database records	Data Manipulation	SR-08, SR-10, SR-11, SR-12, SR-16, SR-19	Unsafe queries or weak database protection may corrupt stock, supplier, or order records.	Parameterized queries, ORM validation, database constraints, secure storage, backup, and recovery.

Attacker attempts to connect to spoofed or unauthorized database	Impersonation / Spoofed Service	SR-15, SR-16, SR-20	If database identity is not validated, the application may send data to a fake or unauthorized database.	Database TLS, certificate validation, secure secrets, network restrictions, and verification testing.
Insider misuses permitted access to view or export sensitive business data	Collection / Exfiltration	SR-05, SR-06, SR-10, SR-17, SR-18	Authorized users may misuse access to supplier records, reports, or inventory data.	Least privilege, RBAC, supplier/order data protection, audit logging, monitoring, and access reviews.